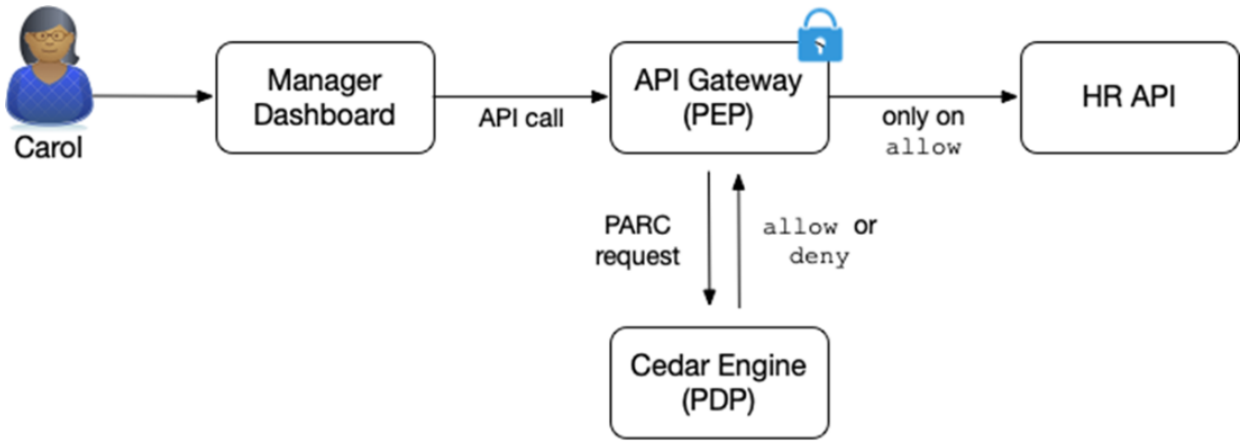


Figure 11.1 API Gateway as a centralized enforcement point. Carol's request moves through the Manager Dashboard to the HR API. The API Gateway functions as the PEP, forwarding a normalized PARC request to the Cedar engine (PDP). The HR API receives the call only if Cedar returns an "allow" decision.

ACME wanted managers like Carol to view salaries only for their own department, not for others. Alice's team described this requirement as a Cedar policy.

```
permit(
    principal,
    action == Action::"view_salaries",
    resource in ACME::Department
)
when {
    principal.role == "manager" &&
    resource.id == principal.department_id
};
```

With that policy in place, a typical request from the Manager Dashboard might look like this:

- Principal: Carol (employee ID, role = manager)
- Action: `view_salaries`
- Resource: Department("marketing")
- Context: calling service = Manager Dashboard

Cedar returns `allow` when Carol is viewing salaries for her own department, and the gateway forwards the call. If she tries to view another department's